

SECURING GLOBALPHARMA

A 12 months cybersecurity culture, awareness and organizational improvement plan



UNIVERSITÀ DI PISA

Matteo Bellini, Giorgio Cecchi, Luca Giannini, Andrea Luchetti e Jacopo Zecchi

2026

INTRO

GlobalPharma is an established company in the medical and pharmaceutical domain that is expanding across the world providing its products and health services.

To contribute safely to this growth we need to tackle in an effective and efficient way the cybersecurity posture of the company to increase trust of the customers and patients.

&

CHALLENGES



ORG. & GOV.

Lack of centralized governance and unclear roles across regions weakens coordination between global strategy and local execution.

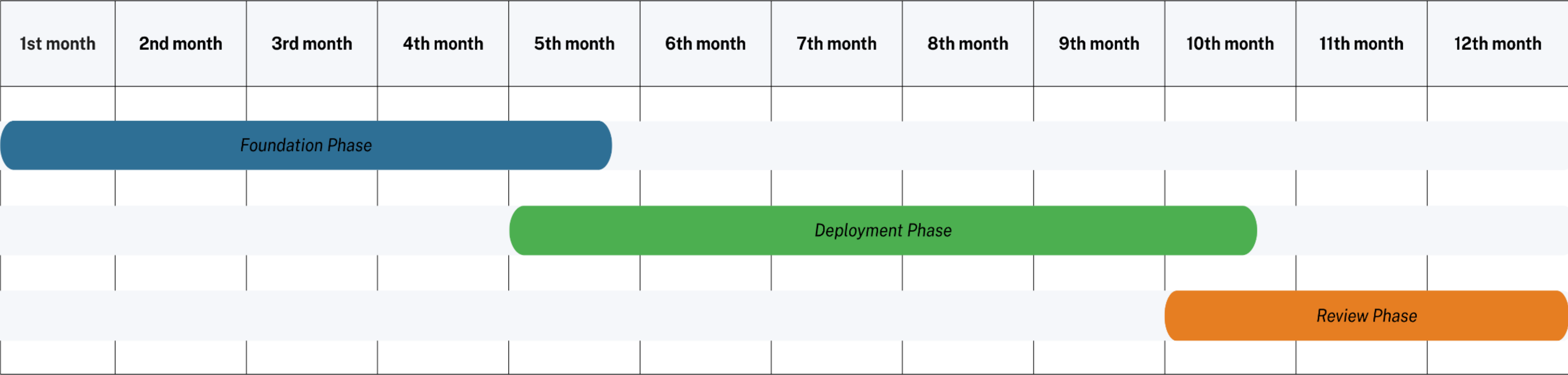
CULTURE

An inconsistent security culture and low awareness hinders the adoption of a security-by-design approach across the organization.

POLICY

Fragmented policies and missing standards prevent a unified governance framework and consistent compliance at a global level.

TIMELINE



Determine the basis for the new strategy implementation.

- Roles' formalization & Security HUB
- Definition of KPIs
- New cybersecurity policies

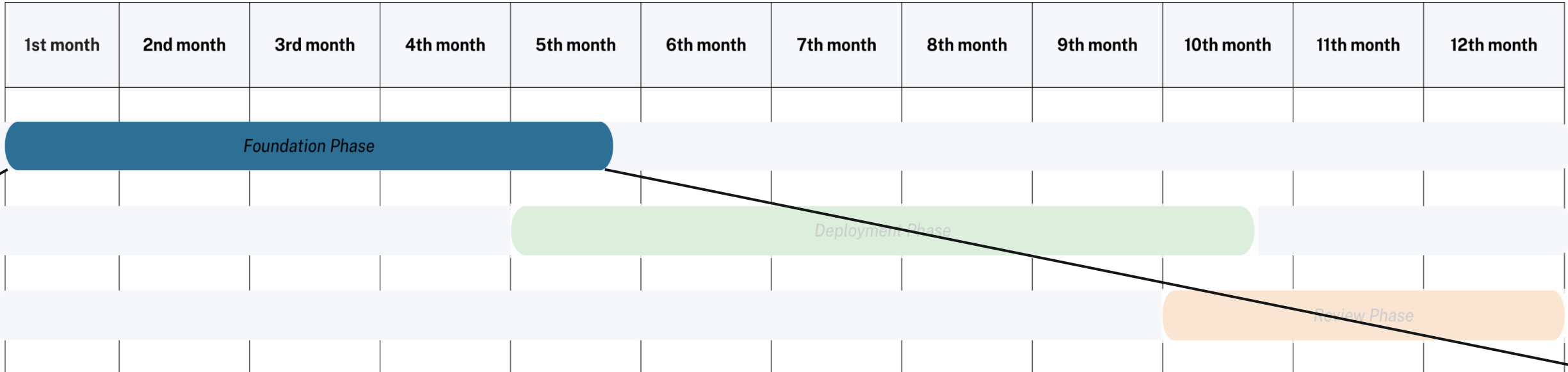
Implement the strategy to build knowledge, raise awareness, and drive cultural change.

- Activation of the Security HUB
- Role based training
- Activation of security champions
- Awareness campaigns

Measuring the impact of the changes and providing feedback.

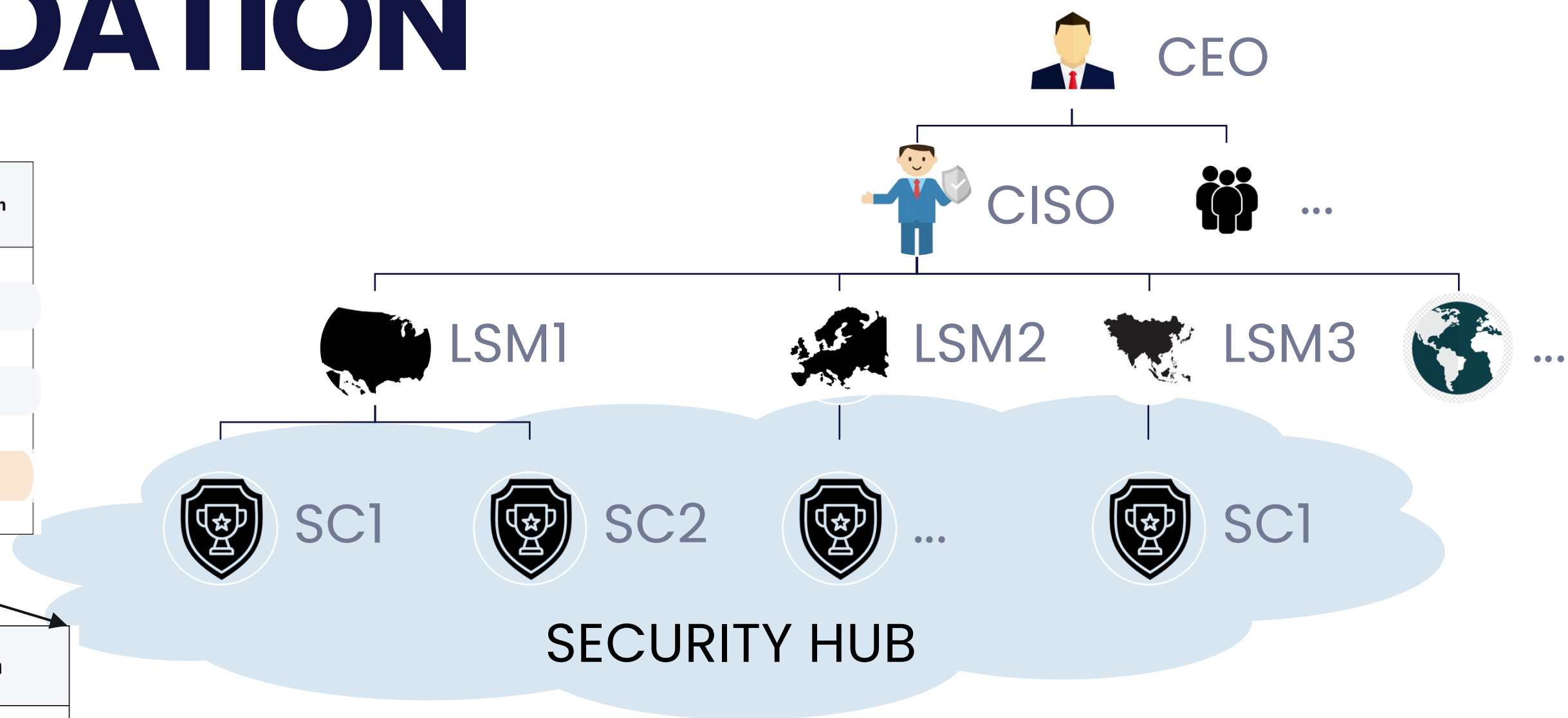
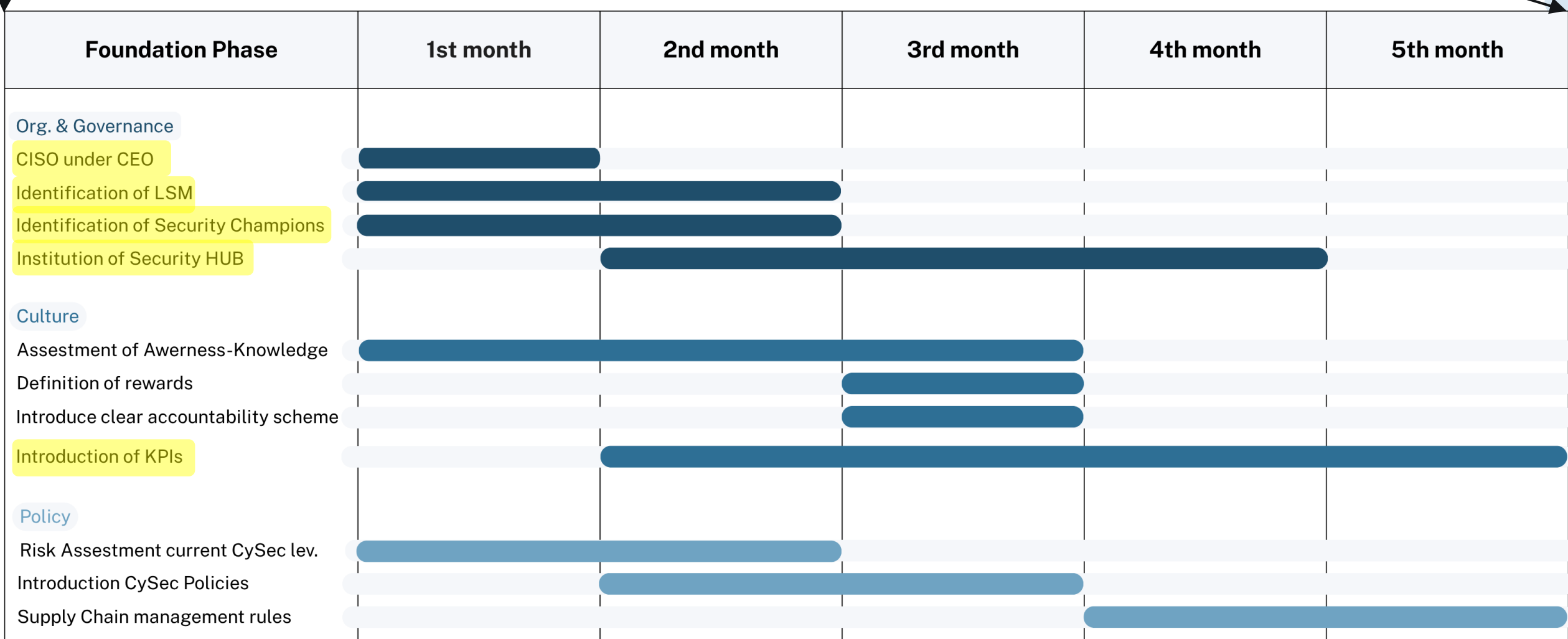
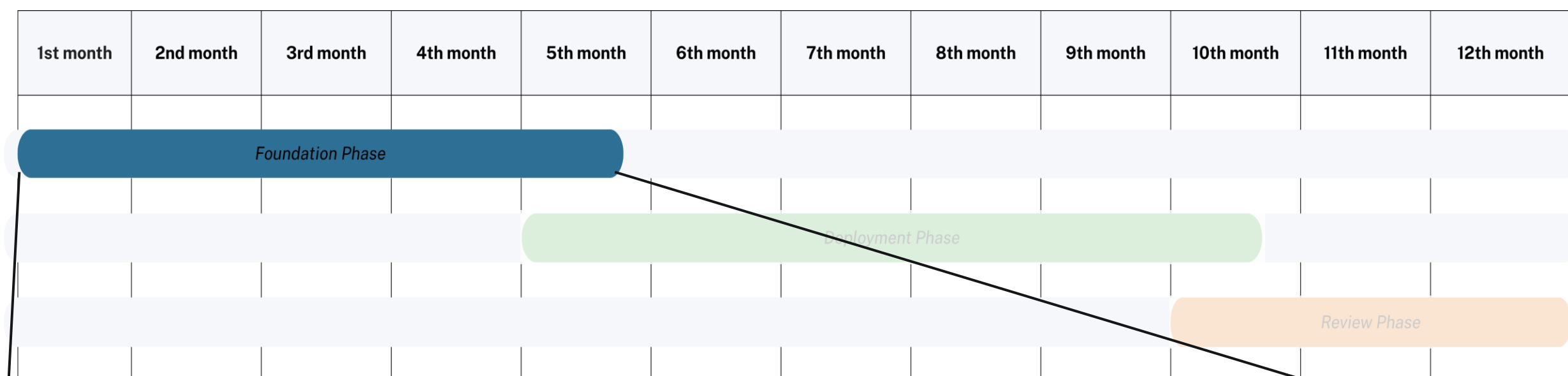
- KPI measurements
- Remediation
- Rewards

FOUNDATION



Foundation Phase		1st month	2nd month	3rd month	4th month	5th month
	Org. & Governance					
	CISO under CEO					
	Identification of LSM					
	Identification of Security Champions					
	Institution of Security HUB					
	Culture					
	Assestment of Awerness-Knowledge					
	Definition of rewards					
	Introduce clear accountability scheme					
	Introduction of KPIs					
	Policy					
	Risk Assestment current CySec lev.					
	Introduction CySec Policies					
	Supply Chain management rules					

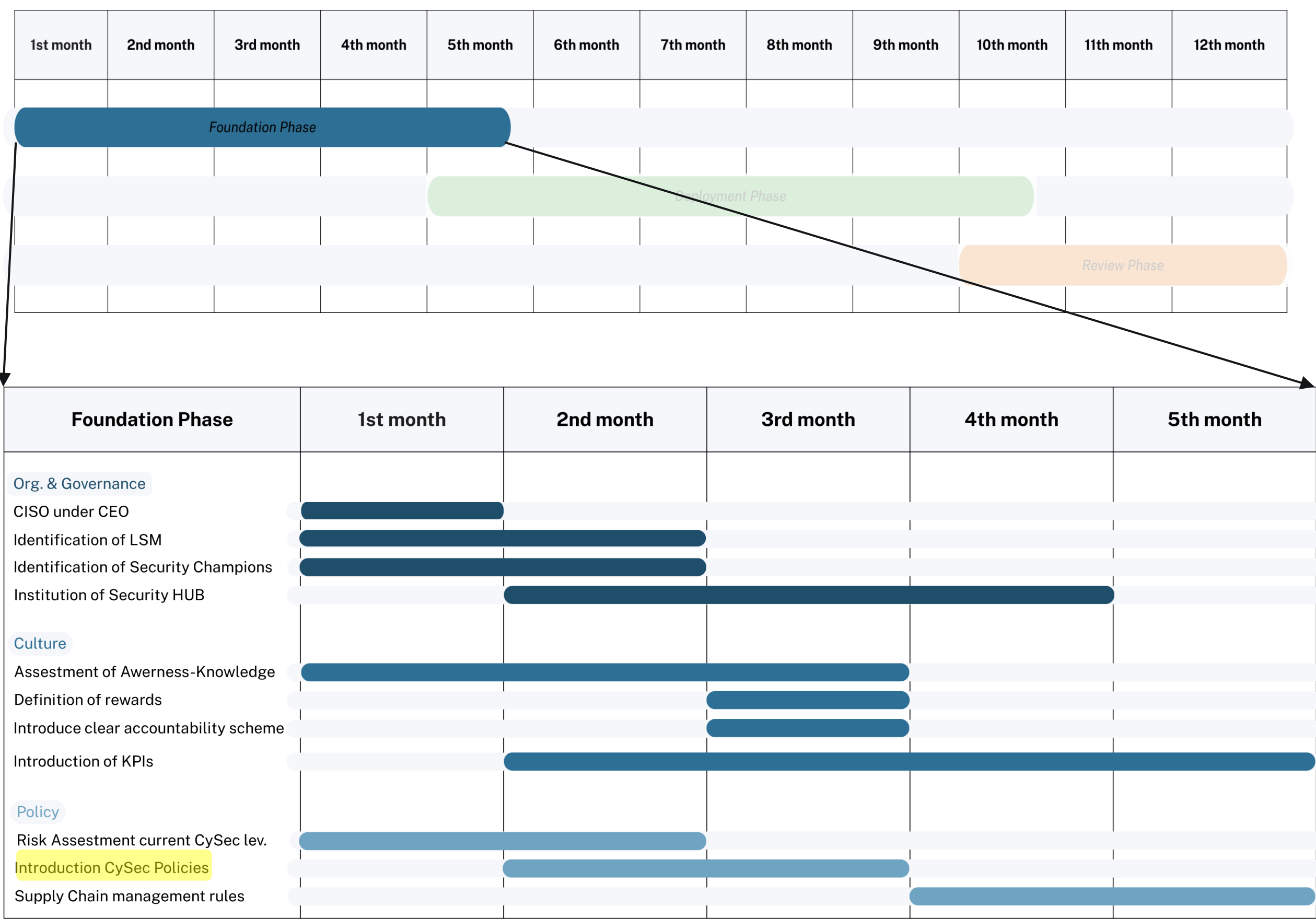
FOUNDATION



KPI Examples:

- % of phishing simulation click rate
- Average security assessment score
- Incident response time
- # of non-conformities issues discovered during audits
- % of departments with active security champion
- % of monthly reports delivered

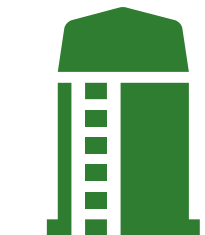
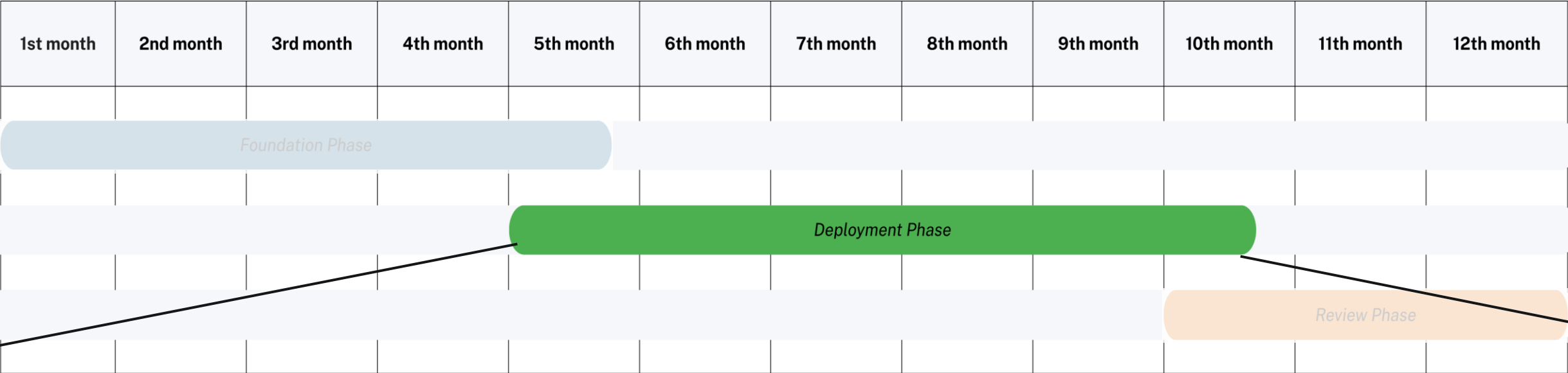
FOUNDATION



CySec Policy Examples:

- Monthly report between CISO, LSM, Security Champions
- Security-by-design: mandatory consultation of LSM for security approval before release
- Mandatory role-based training
- Define incident response plan
- Regular incident simulations

DEPLOYMENT



Org. & Governance

Activation of the Security HUB

Activation of the LSM

Activation of the Security Champions



Culture

Start role based training

Start awareness campaigns and gamification

Incident simulation



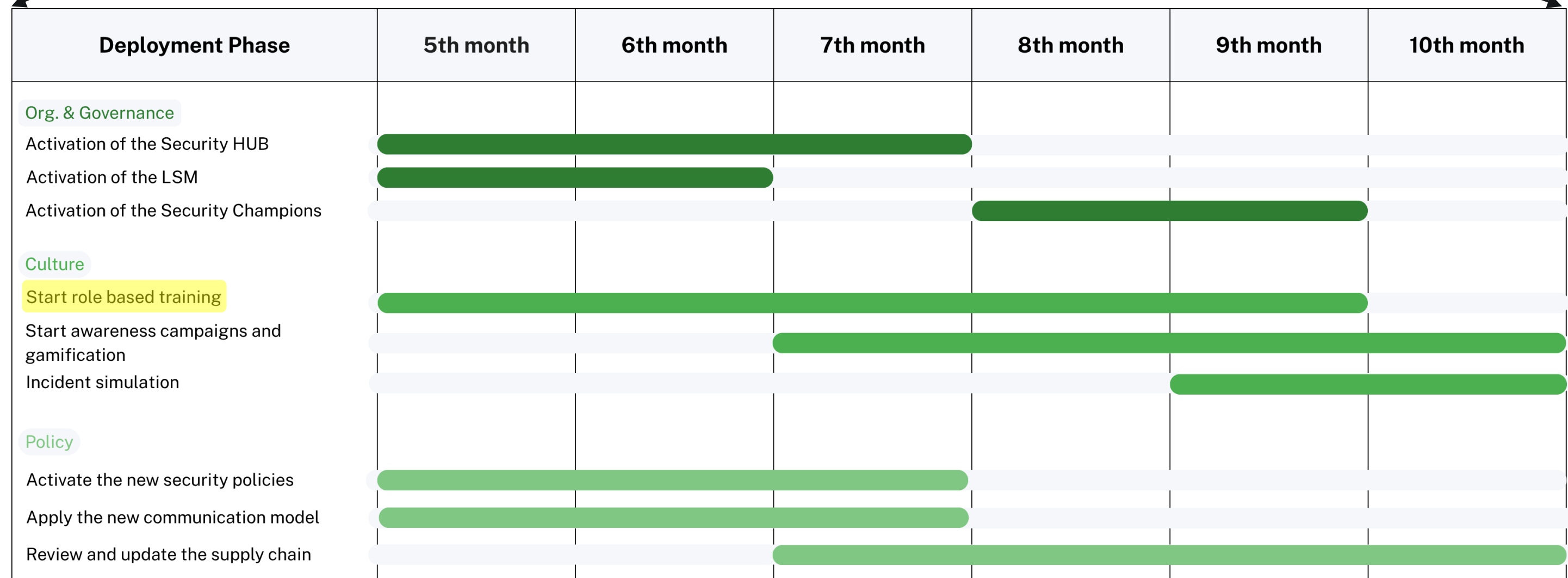
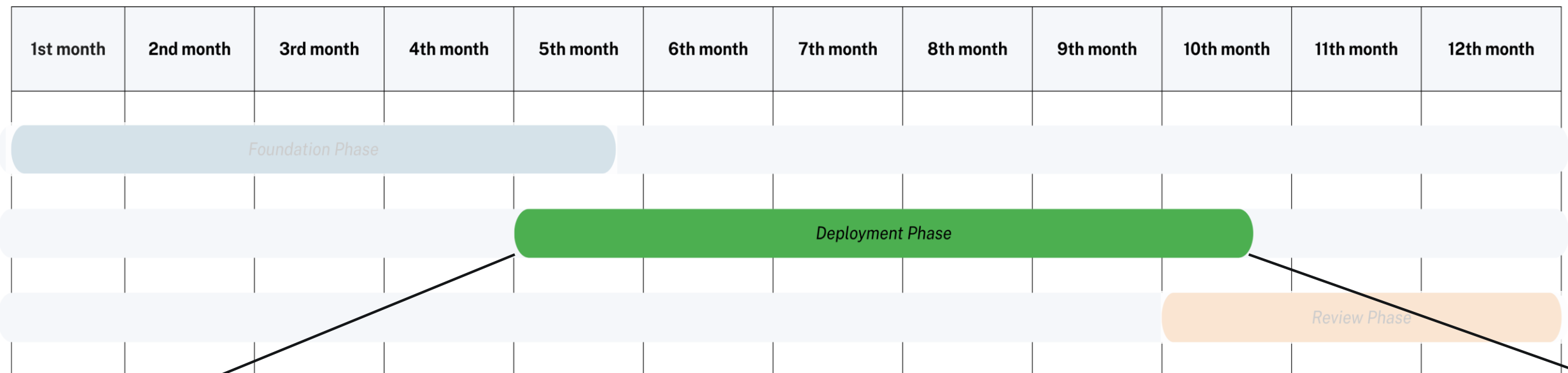
Policy

Activate the new security policies

Apply the new communication model

Review and update the supply chain

DEPLOYMENT



Role based training objectives:

- **Board and top management:** cyber-risk aware decision making
- **Middle management:** cybersecurity integration in projects and risk supervision
- **IT and engineering:** application of security-by-design principles
- **Local Security Managers:** cybersecurity coordination at regional level
- **Security Champions:** promote security best practices and give operational support
- **General employees:** reduce human risk

DEPLOYMENT



Awareness campaigns and gamification:

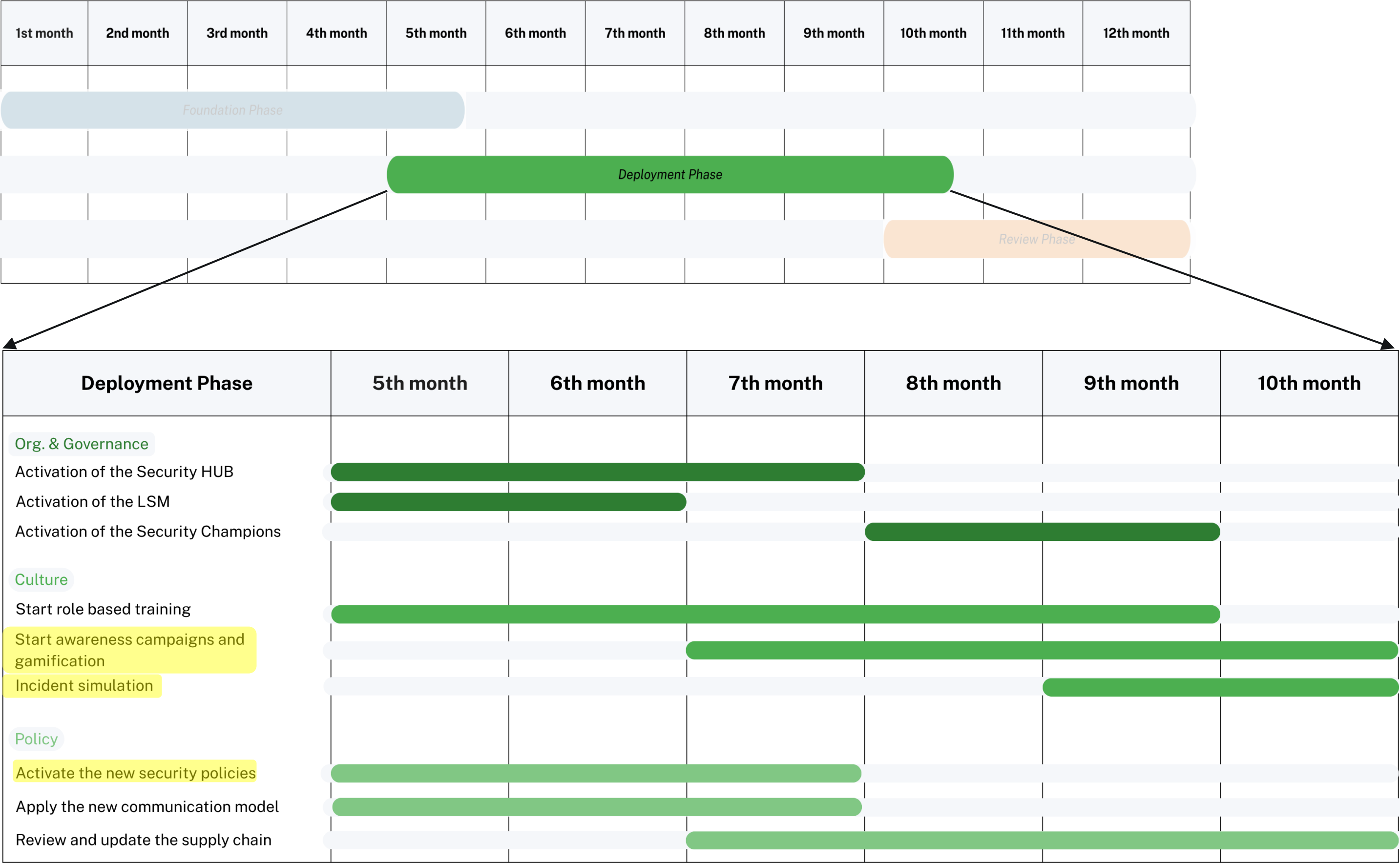
- Phishing awareness campaign: “Think Before You Click”
- Department leaderboard
- Cybersecurity mascot: “Captain Pharma Shield»

KPI measurement

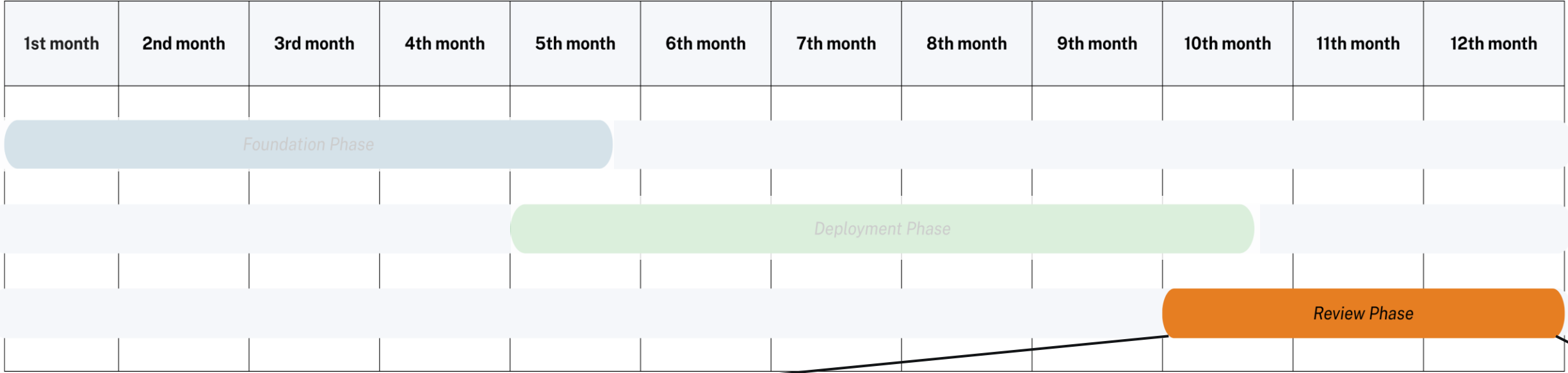
- To be performed halfway of the phase

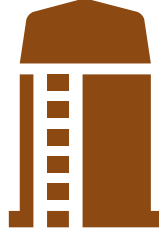
Final incident simulation

- To measure the effectiveness of the training on culture and knowledge

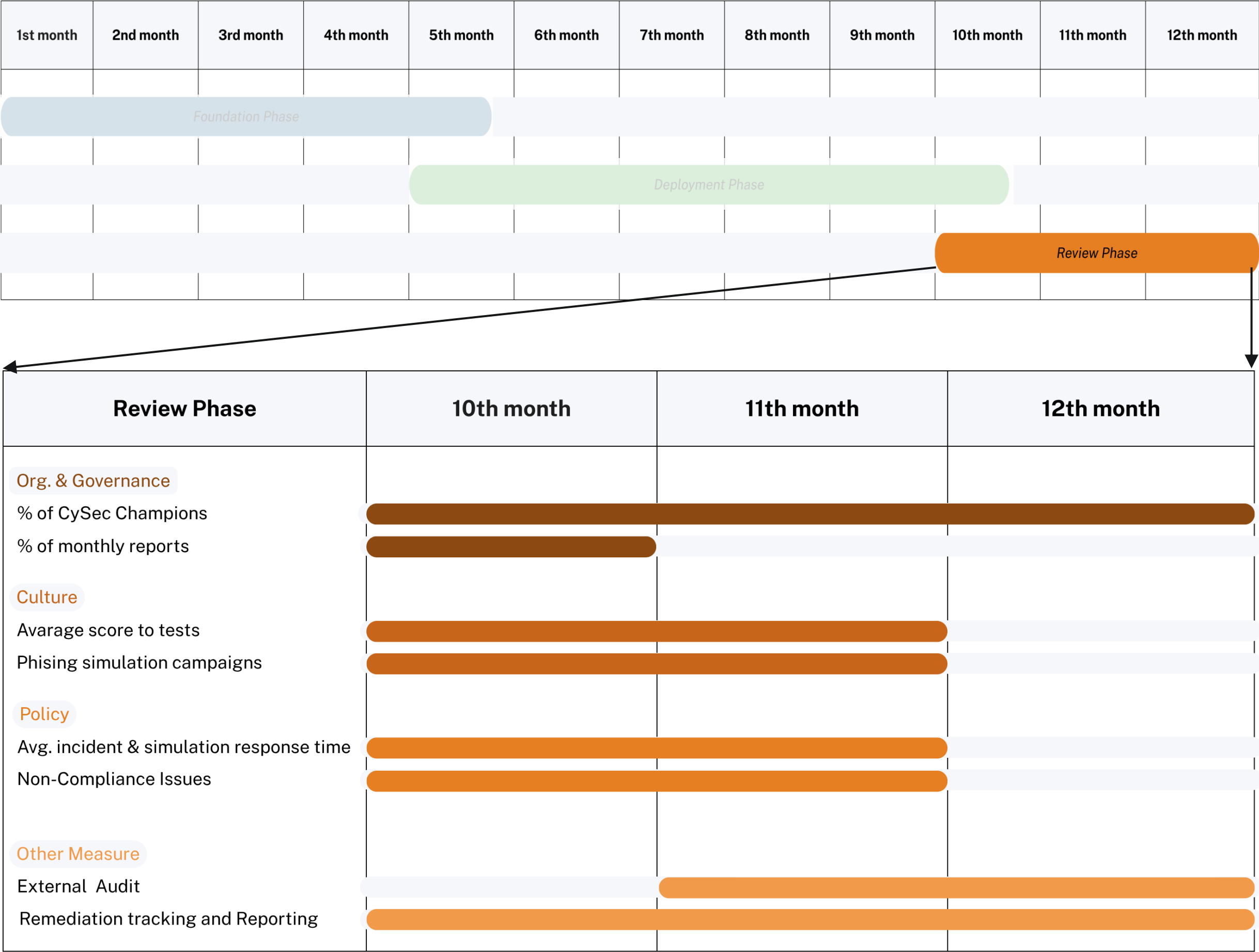


REVIEW



Review Phase		10th month	11th month	12th month
 Org. & Governance	% of CySec Champions			
	% of monthly reports			
 Culture	Avarage score to tests			
	Phising simulation campaigns			
 Policy	Avg. incident & simulation response time			
	Non-Compliance Issues			
 Other Measure	External Audit			
	Remediation tracking and Reporting			

REVIEW



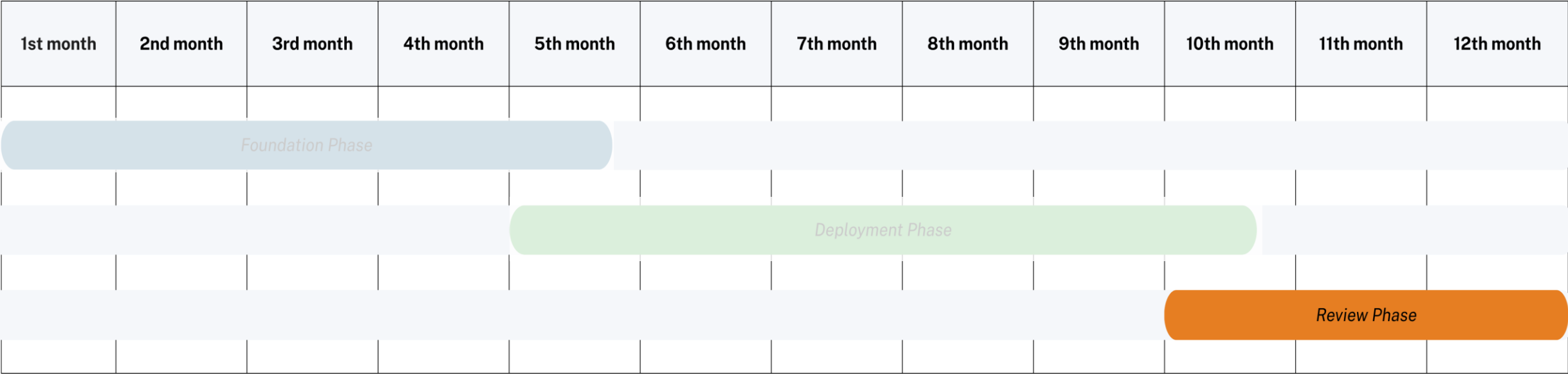
Rewards:

- **Management Bonuses:** Cyber-KPIs tied to annual monetary bonuses for all managers.
- **Spot Monetary Awards:** Immediate cash/vouchers for reporting real threats.
- **Leaderboard Prizes:** Team-building funds and rewards for top departments.

KPI Target Values:

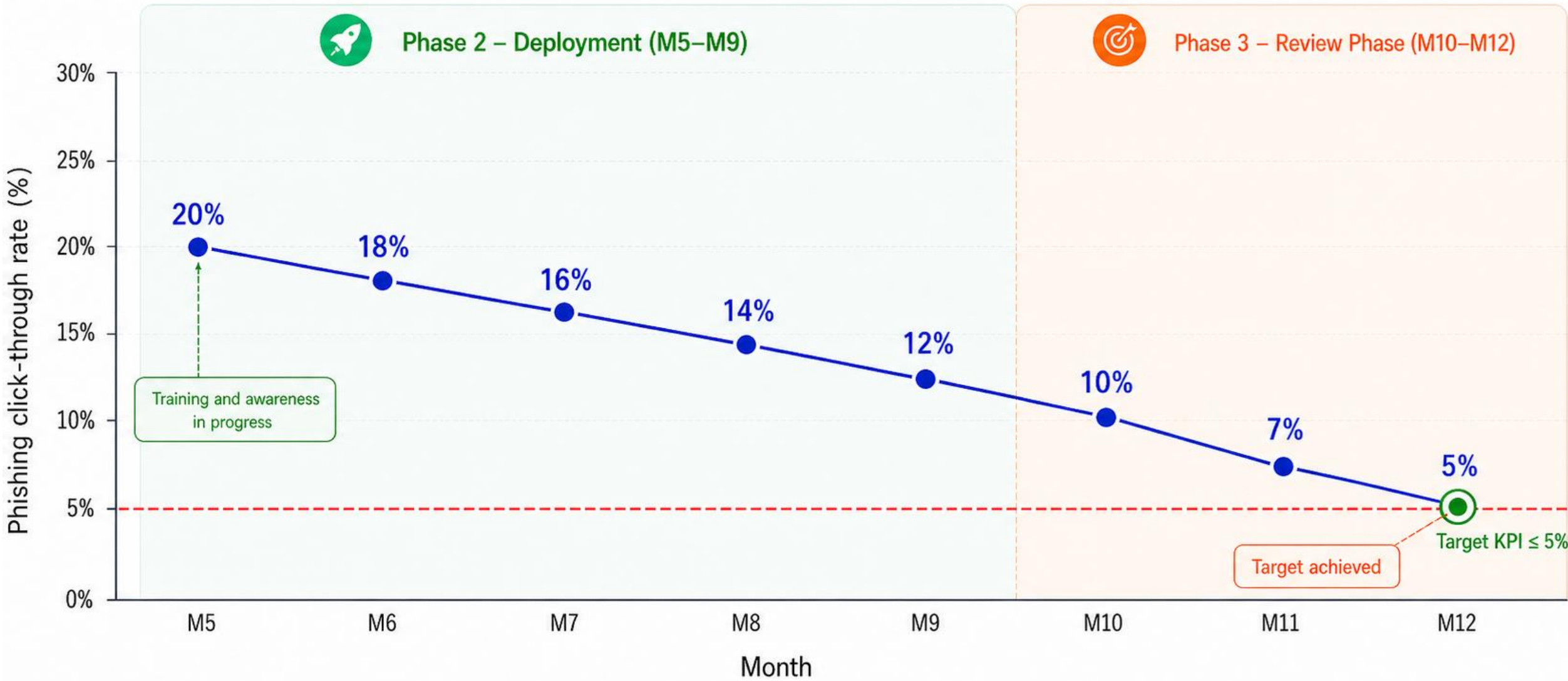
- Average Security Assessment score → $\geq 80\%$
- Incident Response Time → {1h, 8h, 72h}
- # of non-conformities issues discovered during audits → {0, 3}
- % of departments with active Security Champion → $\geq 90\%$
- % of monthly Reports delivered → $\geq 90\%$
- % of Phishing simulation click rate → $\leq 5\%$

REVIEW



KPI Trend – Phishing Simulation Campaigns

Reduction in the phishing click-through rate over 12 months



Remediation Tracking:

- **Corrective Action Register:** Formal logging of unmet KPIs to identify root causes and assign specific owners.
- **Structured Follow-up:** Strict monitoring of remediation deadlines to ensure that every performance gap is closed within 30 days.

Stakeholder Reporting:

- **Operational Level:** Detailed KPI dashboards for Security Champions and Local Managers to drive local improvements.
- **Executive Level:** High-level summaries for the CISO and the Board focusing on global compliance posture and residual risk.

Certification:

- **Institutional Trust:** Leveraging certification to increase the confidence of patients, customers, and global health partners.
- **ISO 27001 Standard**



CONCLUSIONS

New Org. & Governance: From organizational silos to a direct CISO–CEO reporting line, ensuring cybersecurity is a board-level priority.

Proactive Culture: Transforming knowledge into behavior through targeted training, rewards, and accountability.

Unified Policy: Redefinition of the cybersecurity policy and adoption of a new communication model.

A light gray world map is centered in the background of the image. The continents are clearly outlined, including North America, South America, Europe, Africa, Asia, and Australia. The map is rendered in a minimalist, flat style.

THANK YOU